

MCCoE CYBERSECURITY APPRENTICESHIP PROGRAM
PROJECT 8 OF 8 — PART 2: FRAMEWORKS + EXECUTIVE SUMMARY
EQUIFAX DATA BREACH (2017)

Unpatched CVE · 147 Million SSNs Stolen · 76 Days Silent · \$575M Settlement

THIS PROJECT: Apply the NIST CSF and pentesting methodology. Write and present your professional Executive Summary. This project ends with your Executive Summary submission (100 points).

PROJECT 8 · DAY 6	MONDAY — NIST CSF — DEFENSIVE FAILURE ANALYSIS	1-2 HRS
-------------------	--	---------

OBJECTIVE: Students apply all 5 NIST Cybersecurity Framework functions to identify exactly what the organization did wrong and what they should have done.

CLASS SCHEDULE

TIME	ACTIVITY	DETAIL / INSTRUCTIONS
0:00-0:20	Project Launch + Review	Quick recap of last project findings. Preview this project: today = defender perspective. What failed? What should have existed?
0:20-0:50	Lecture: NIST CSF	Teach the 5 functions. Draw a timeline on the board — overlay NIST. Show: Identify/Protect are BEFORE. Detect/Respond/Recover are DURING and AFTER.
0:50-1:40	NIST Failure Analysis	Students fill out the NIST table: for each function — specific failure + specific corrective action. No vague answers.
1:40-2:00	Critical Failure Vote	Which NIST function had the most catastrophic failure? Students vote and justify their answer. Discuss.

🎯 **OBJECTIVE:** Students map the attacker's actions to the 5 pentesting phases. Think like an attacker to become a better defender.

CLASS SCHEDULE

TIME	ACTIVITY	DETAIL / INSTRUCTIONS
0:00-0:30	Lecture: 5 Pentest Phases	Teach Reconnaissance, Scanning, Gaining Access, Maintaining Access, Covering Tracks. Why thinking like an attacker makes you a better defender.
0:30-1:10	Methodology Mapping	Students map the attacker's specific actions in this incident to each of the 5 phases. Include specific tools or techniques used.
1:10-1:40	Attacker vs Defender Game	For each phase: students suggest what the attacker did AND what a defender could have done to detect or stop it.
1:40-2:00	Homework Briefing	Assign: Tonight, outline your full Executive Summary using the template. Every section must have at least 3 bullet points before you write.

🎯 **OBJECTIVE:** Students develop and workshop 5 specific, actionable recommendations. Peer collaboration to pressure-test each recommendation.

CLASS SCHEDULE

TIME	ACTIVITY	DETAIL / INSTRUCTIONS
0:00-0:20	From Here On Out Review	Go through the "From Here On Out" section together. Discuss: are these the right priorities? Would you add anything?
0:20-1:00	Recommendations Workshop	Students draft their 5 recommendations with justification. Then pair up: each partner challenges one recommendation — is it specific enough? Does it address this incident?
1:00-1:30	Priority Debate	Class votes on the single most important recommendation. Each student defends their #1. Group builds a consensus top 5.
1:30-2:00	Executive Summary Drafting	

🎯 **OBJECTIVE:** Students complete peer review, deliver professional executive summary presentations, submit, and debrief the full incident.

CLASS SCHEDULE

TIME	ACTIVITY	DETAIL / INSTRUCTIONS
0:00-0:30	Writing + Peer Review	Students finalize all 9 sections of the Executive Summary. Swap with a partner: (1) strongest section, (2) one section needing more specifics, (3) one fact missed.
0:30-1:00	Revision Time	
1:00-1:45	Presentations + Submission	Each student presents 3-5 minutes. Collect completed Executive Summaries (100 pts). Class gives structured feedback: one strength, one specific improvement.
1:45-2:00	Full Debrief + Next Project Preview	What is the single most important lesson from this incident? What would you tell an IT team to do first thing Monday morning? Preview the next project.

NIST CSF FAILURE ANALYSIS REFERENCE

NIST FUNCTION	WHAT FAILED	WHAT SHOULD HAVE HAPPENED
Identify	FAILED — CVE-2017-5638 not identified for patching; expired SSL certificates not tracked	Conduct regular asset inventories, vendor risk assessments, and map all third-party connections
Protect	FAILED — 69-day patch delay; expired SSL inspection certificate = 19 months of blind traffic	Implement NIST SP 800-53 controls. Enforce MFA, patching SLAs, network segmentation
Detect	FAILED — 9,000 database queries over 76 days went undetected; no anomaly detection on database queries	Deploy SIEM, IDS/IPS, behavioral analytics. Set up 24/7 monitoring with mandatory alert response SLAs
Respond	FAILED — 40+ days to notify public after discovery; executives sold stock before disclosure	Develop and TEST an incident response plan. Establish clear escalation paths
Recover	PARTIAL — \$575M settlement; new CISO hired; credit monitoring offered; security program overhauled	Implement and test backup/recovery. Define RTO and RPO. Conduct tabletop exercises regularly

ATTACKER METHODOLOGY — 5 PHASES REFERENCE

PHASE	WHAT THE ATTACKER DID IN THIS INCIDENT
Reconnaissance	Scanned for internet-facing Apache Struts; CVE-2017-5638 was public — minimal effort required
Scanning	After initial exploitation, mapped Equifax's internal network; found 48 databases containing PII
Gaining Access	Exploited publicly known CVE with freely available proof-of-concept code
Maintaining Access	Web shells provided persistence; expired SSL cert gave 19 months of uninspected traffic
Covering Tracks	Exfiltrated in small batches over 76 days to avoid triggering volume-based alerts

"FROM HERE ON OUT" — RECOMMENDATIONS REFERENCE

 **NOTE:** These are the controls that, if in place, would have prevented or significantly reduced this breach.

- **MANDATE:** Critical patch SLA — CVEs rated CVSS 9.0+ on internet-facing systems patched within 72 hours, no exceptions
- **MANDATE:** SSL/TLS certificate lifecycle management — automated monitoring and renewal for all certificates
- **MANDATE:** Vulnerability scanning — scan ALL internet-facing applications weekly
- **IMPLEMENT:** Database activity monitoring — alert on unusual query volumes, off-hours access, bulk retrieval
- **IMPLEMENT:** Web Application Firewall (WAF) — a properly configured WAF could have blocked CVE-2017-5638
- **IMPLEMENT:** Network segmentation — web servers should NOT have direct access to databases containing SSNs
- **IMPLEMENT:** Data minimization — if you don't need to store it, delete it

REFERENCES & RESOURCES

- nvd.nist.gov/vuln/detail/CVE-2017-5638 — full technical details, CVSS score, references
- U.S. House of Representatives Report: "The Equifax Data Breach" (December 2018) — oversight.house.gov
- FTC: "Equifax to Pay \$575 Million" — ftc.gov (July 22, 2019)
- Apache Security Bulletin S2-045 — struts.apache.org/security/security-bulletins
- CISA Known Exploited Vulnerabilities Catalog: cisa.gov/known-exploited-vulnerabilities-catalog
- MITRE ATT&CK: attack.mitre.org — search T1190, T1059, T1048